

CONTINUATION — Helix

Proxy: VPN-Aware Dynamic Routing Extension

Revision: 17 **Last modified:** 2026-07-02T07:05:29Z **Status:** Active — **§11.4.126 autonomous loop** (operator: "keep hardening, don't tag yet" + "3-4 parallel subagents, rock-solid evidence, no bluff" + "all future work on main"). **Rev-17 wave (HEAD 91af9c6, branch main, FF to origin): §11.4.107 underlay-sniff AF_PACKET non-leak differential landed on the WG substrate.** 91af9c6 adds to hermetic_wg_roundtrip.sh a rootless AF_PACKET capture on the underlay veth0 during the positive round-trip asserting BOTH (a) WG **ciphertext present** (type-4 0x04 datagram to :51820) AND (b) the per-run **plaintext nonce ABSENT** in raw underlay bytes — a different-domain oracle (§11.4.107(2)) + the canonical WireGuard self-audit method; the third independent layer of the tunnel-integrity claim after §11.4.111 destination-binding + wrong-destination negative. **Independent §11.4.142 review a2b3c696 = GO on 11/11 checks against real runs (§11.4.134):** load-bearing golden-bad SNIFF_MUT=plain (emits the nonce as cleartext UDP to discard :9, distinct from the §11.4.111 TCP :8080 control) flips ONLY assertion (b) to FAIL 3/3 while ciphertext stays present (not a tautology, §11.4.107(10)); NORMAL → ciphertext(0x04 :51820)=present plaintext_nonce=absent 3/3; header-only pcap → analyzer exit 3 (honest FAIL); forced-iface + no-tcpdump → honest SNIFF-SKIP; WG_MUT=badkey tooth undisturbed (sniff sits past the UP! =1 gate); veth0-only capture, 3.5 s / 4 MB / timeout-bounded, SNIFF_PID reaped, wg0-mullvad untouched (§11.4.174); sh -n + bash -n clean. FINDINGS.md → Rev 4 §7 (PLANNED → IMPLEMENTED). Two tracked follow-ups: **task #64** one-line Ethernet-ethertype guard on the frame analyzer (reviewer nit — VLAN offset shift, structurally impossible on the harness's own fresh veth, correct-by-construction); **task #65** fan the differential out to the 4 protocol harnesses (bridge/ftp/webdav/email), each with a per-protocol plaintext marker + its own SNIFF_MUT=plain. **Anti-bluff §11.4.118 pass this wave:** a mechanical smell-scan of all 26 test scripts (bare ab_pass, || true-before-verdict, fail-open SKIP→PASS, unconditional PASS) came back clean — enumerated coverage evidence, with the honest boundary that grep cannot catch a *semantic* tautology (only adversarial re-run can, as in the #62 negative-control fix). **Next: task #64 (tiny) or #65 (fan-out) — the loop continues (no tag — "keep hardening").** Rev-16

wave (HEAD 4dd5fc6, branch main, all FF to origin): §11.4.111 wrong-destination negative control added to all 5 hermetic harnesses + FINDINGS §7 (next hardening) designed.

4dd5fc6: after each positive round-trip, the harness probes the peer's service on the UNDERLAY IP 10.9.0.2 and asserts it FAILS (the peer binds the WG-only overlay 10.10.0.2, so a positive success could only have traversed wg0 — reachability-as-proof made self-evidencing, not structural-only); a wrong-destination SUCCESS = fail-closed. **Independent §11.4.142 review ran TWO rounds (iterate-to-GO §11.4.134):** round 1 caught a REAL tautology (§11.4.107(10)) — hermetic_wg_roundtrip.sh probed /payload.txt but rm'd \$SRVDIR BEFORE the probe, so a reachable underlay 404'd and NEG-OK printed unconditionally (proven by the reviewer binding the peer to 0.0.0.0: pre-fix the harness wrongly PASSED); fix = defer the SRVDIR cleanup to AFTER the control, so post-fix bind-0.0.0.0 ⇒ WG_FAIL ... unexpectedly served the payload exit 1 (control now load-bearing), NORMAL still PASS, WG_MUT=badkey tooth still fires, 3/3 deterministic; round 2 re-verified ⇒ GO. The other 4 controls (bridge/ftp/webdav/email) were proven load-bearing in round 1 (each FAILs when its peer binds 0.0.0.0). Part (b) (/usr/sbin/wg preflight) was already satisfied in all 5 — verified, no redundant edit (§11.4.6). FINDINGS.md Rev 3 §7 designs the next hardening — the **underlay-sniff AF_PACKET non-leak differential** (assert WG ciphertext 0x04 present + plaintext nonce absent on the underlay), cited §11.4.99/§11.4.150, **queued as task #63** (blocked-by #62, now unblocked). Anti-bluff win: a decorative NEG-OK that gated nothing was REFUSED by review, not shipped. **Next: task #63 (underlay-sniff) — the loop continues (no tag — "keep hardening").** Rev-15 wave (HEAD 3b73f02, branch main, all FF to origin): **H2.email promoted + all hermetic promotions wired into the standing suite as regression guards.** 71e0bac added test_vpn_lan_hermetic() to tests/run-tests.sh — the 4 hermetic harnesses (hermetic_wg_roundtrip.sh, hermetic_bridge_run.sh/Cast-eureka, hermetic_ftp_run.sh, hermetic_webdav_run.sh) now run on every suite invocation as **§11.4.135 standing regression guards** under a SKIP-aware verdict map (rc0+PASS≥1+FAIL0⇒PASS; rc0+SKIP≥1+PASS0+FAIL0⇒SKIP; else FAIL), independent §11.4.142 review GO (7/7 adversarial HOLD; 4/4 real + 7/7 synthetic mapping). 3b73f02 landed **H2.email:** hermetic_email_run.sh runs the **UNMODIFIED** email_roundtrip.sh autonomously over the tunnel via a pure-stdlib implicit-TLS mail peer (SMTPS 465 / IMAPS 993 / POP3S 995, shared in-memory mailbox) bound to the WG-only overlay 10.10.0.2 (reachability = tunnel-traversal proof §11.4.111). **Independent §11.4.142 adversarial review = GO, no blocking findings (§11.4.134):** NORMAL PASS all 4 scored legs (imaps_login_list, smtp_submission_send, pop3s_retrieve_roundtrip, open_relay_refused; email_reverse_leg SKIP N/A), MAIL_MUT=openrelay→real FAIL: open_relay_refused (only that leg), MAIL_MUT=droptoken→real FAIL: pop3s_retrieve_roundtrip (only that leg) — **both teeth load-bearing + targeted;** 3/3 deterministic (§11.4.50); §11.4.10 no cred/key leak (AUTH base64

= server RFC 4954 challenges only); clean cleanup (§11.4.14); wg0-mullvad untouched (§11.4.174). The close_notify fix (tls.unwrap() before close) + IMAP bare-QUIT clean-close eliminate the silent-SKIP-masking class (§11.4.6) — all legs ran live; builder self-debug (§11.4.102) also fixed the PoC shutdown() self-recursion + an IMAP -ign_eof hang. FINDINGS.md→Rev 2 (**§6 implicit-TLS mail deep-research** §11.4.150: PEP 594 smtpd removal, RFC 8314/5321/4954/3501/1939, the close_notify FACT + sources) + companion hermetic_email_run.md Rev 1, all HTML+PDF synced 0-fence-leak (§11.4.168). **Honest gate verdict (§11.4.6): the clean zero-install protocol-promotion set is now COMPLETE (Cast-eureka + FTP + WebDAV + email).** Remaining legs genuinely operator-gated (§11.4.122/§11.4.3): SFTP (no sshd), SMB/NFS (no samba/nfsd), discovery_reflect.sh scored leg (no avahi-browse client), ADB (device), container (podman). **Follow-up (separate reviewed batch): explicit wrong-destination negative (underlay/wg-down MUST-fail) to make §11.4.111 self-evidencing + wg-preflight /usr/sbin/wg across sibling harnesses. Next: the loop continues (no tag — "keep hardening"). Rev-14 wave (HEAD 3b98d02, branch main, all FF to origin): H2.x hermetic protocol promotions — three operator-gated protocol legs now run AUTONOMOUSLY over the hermetic kernel-WireGuard tunnel (§11.4.52).** 18a21bd landed H2 = the UNMODIFIED chromecast_dial.sh eureka control leg promoted (hermetic_bridge_run.sh, stdlib eureka peer 10.10.0.2:8008, H2_MUT=badeureka teeth, self-fetch name-nonce). 3b98d02 landed **H2.ftp + H2.webdav:** hermetic_ftp_run.sh (embedded ~85-line stdlib FTP server 10.10.0.2:2121, PASV/EPsv both traverse wg0 §11.4.111, harness content-verifies a self-RETR against ground truth §11.4.107(9), FT_MUT=empty teeth) + hermetic_webdav_run.sh (stdlib 207 origin 10.10.0.2:8080 reached THROUGH a stdlib forward proxy 127.0.0.1:3128 RFC 7230 §5.3.2→§5.3.1, WEBDAV_MUT=bad207 = the exact PASS gate). Both harnesses additionally **scrub ambient-shell sibling-leg env vars** before invoking the promoted test (§11.4.50 determinism, independent-review nit — false-negative guard, never a bluff PASS). **All verified GREEN: FTP normal+teeth, WebDAV normal+teeth (207 through proxy, self-fetch body 779 B), both 3/3 deterministic; independent §11.4.142 review returned GO on both.** WebDAV harness was drafted by a session-limit-crashed builder subagent, resumed residue-clean per §11.4.147. Feature Status bumped to **Rev 3 (new §J)** + Status_Summary Rev 3 + companion docs hermetic_ftp_run.md (Rev 2) / hermetic_webdav_run.md (Rev 1) + research FINDINGS.md, all with synced HTML+PDF (0 fence-leaks §11.4.168). **Honest gate verdict (§11.4.6):** the clean zero-install promotion set is now COMPLETE (Cast-eureka+FTP+WebDAV); SFTP needs sshd (absent, no stdlib SSH server), SMB/NFS need samba/nfsd, discovery_reflect.sh scored leg hard-requires the absent avahi-browse client, ADB/container need device/podman — all genuinely

operator-gated (§11.4.122/§11.4.3). **Email (SMTP-implicit-TLS + POP3S/IMAPS) is pure-stdlib-feasible and under active de-risking** — a standalone TLS-mail PoC subagent (ac86a45fcd50747dd) is in flight before any hermetic_email_run.sh.

Next: on PoC GO, build+review+land H2.email; the loop continues (no tag — "keep hardening"). Rev-13 wave (HEAD b76065c, branch main, all FF to origin): hermetic-harness H0-FULL DONE — a REAL encrypted kernel-WireGuard tunnel round-trip proven autonomously (b76065c). The planned wireguard-go build was unnecessary: the host wireguard **kernel module** works inside an unprivileged users netns (ip link add wg0 type wireguard + wg set succeed under unshare -Ur; /usr/sbin/wg present) — so H0-full is zero-build/zero-dep/no-package-install/no-podman/no-Mullvad/no-root. tests/vpn_lan/hermetic_wg_roundtrip.sh: veth underlay (10.9.0.x) carries the encrypted WG UDP, wg0 overlay (10.10.0.x) is the tunnel, a real HTTP payload served on the WG-only 10.10.0.2 and fetched over the tunnel — **wg show: latest-handshake=1782947082 rx=452 tx=752, sha256 verified, 3/3 deterministic (§11.4.50); golden-bad WG_MUT=badkey → hs=0/rx=0 → round-trip breaks** (§11.4.107(10)/§11.4.68 — rx=0 proves the WG crypto gates the traffic, not the veth underlay). **Next: H1/H2** — run real peer services (smbd/vsftpd/webdav/eureka/mDNS, unprivileged) + wire HELIX_BRIDGE_MODE=hermetic into tests/lib/sword_bridge.sh so the protocol tests run INSIDE the namespace over the tunnel, promoting the 16 operator-gated SKIPs to AUTONOMOUS (§11.4.52). **Rev-12 wave (was HEAD f96da56, branch main, all FF to origin): consolidation + a game-changing autonomous-validation path. 70f0636 README §11.4.57 doc-link table completed** — all 6 Status pairs listed (the 2 VPN-LAN pairs were missing). 89cfd21 .gitignore .tmp_export/ doc-export scratch (§11.4.30). **1faead5 + f96da56 — the hermetic-WireGuard test-harness path (deep research, §11.4.150/§11.4.52):** a loopback WireGuard pair in **unprivileged** network namespaces (unshare -Ur -n ⇒ root-in-users + userspace wireguard-go, the cmusatyalab/wireguard4netns pattern) would let the **16 operator-gated protocol tests run AUTONOMOUSLY** against a controlled peer — **gated on NEITHER the broken podman NOR the live Mullvad bridge**. Design doc 1faead5 (FACT-probe: kernel.unprivileged_usersns_clone=1, max_user/net_namespaces=255793, unshare -Ur -n rc=0, /dev/net/tun present). **H0 feasibility PROVEN with real physical evidence f96da56:** tests/vpn_lan/hermetic_netns_poc.sh — 2 netns + L3 veth + a real python3 HTTP payload served in the peer, fetched + **sha256-verified byte-for-byte, 3/3 deterministic (§11.4.50), golden-bad POC_MUT=1 FAILs at the sha256 check (§11.4.107(10) teeth load-bearing)**, fully rootless, host-safe (§12, torn down with unshare). Honest scope (§11.4.6): veth not yet WireGuard — proves the substrate; real Mullvad topology stays a §11.4.3 operator-gated confirmation. **Next: H0-full** (build wireguard-go, swap veth→WG tunnel) — deferred pending host process-headroom (transient fork

exhaustion observed §12). **Rev-11 wave (was HEAD 4e2810c, all FF to origin): the VPN-LAN service-access feature is COMPLETE — all Phases 0-12 committed** incl. the operator's **Phase 12 bidirectional exposure** (2ed0fed bidirectional_exposure.md + ingress_allowlist_teeth.sh, wired into the standing suite) and **Phase 1 SSRF carve-out teeth** (suite-wired). **All 5 autonomous VPN-LAN teeth GREEN** (SSRF carve-out + SSRF_MUT, ingress-allowlist + INGRESS_MUT, bridge). Landed also: DNS-rebinding SSRF gap demo + smokescreen design (4e2810c, 7 sources §11.4.150), control-plane coverage **acl-helper 0→53.8%** (4a9b75f) + **cmd/api 0→61.1%** (4e2810c, -race clean, go.sum untouched), §11.4.169 **stress+chaos** (97d9733, 100-iter identical hash) + **benchmark+memory** (4e2810c), deep **OSS survey** (958d110, 28 projects/50 URLs). **§11.4.1 anti-bluff win (7c4345d+4a007a0+30ec5b5):** the standing suite was HANGING forever on the LE phase3 guard (rootless-podman aardvark-dns bind failure); root-caused live (§11.4.102), fixed the LE boot-timeout→SKIP + three latent set -e/pipefail/grep -c suite-abort bugs → the suite now **COMPLETES + honestly reports (74/60/11/3)** instead of masking failures behind a hang. **HOST PODMAN BROKEN (env, operator-actionable, NOT a code defect):** aardvark-dns cannot bind netavark gateway :53 host-wide → proxy containers show "Up (healthy)" but crun says NOT running, :53128/:51080 don't serve, ./start fails identically; a host-level podman/netavark reset is needed but was NOT done autonomously (§11.4.101/§11.4.174 — shared host w/ operator lava-*/deploy_caddy/wg0-mullvad). The 3 suite FAILs are ALL this one condition. **3 subagents in flight:** control-plane coverage r3, bidirectional both-way protocol assertions, §11.4.169 concurrency+load. **(Rev-10 prior:)** **§11.4.126 autonomous loop + VPN-LAN service-access feature (Phases 0/2/3/4/8/9 landed; 5/6/7/10/11 in flight).** **Rev-10 wave (12 commits this session, all FF to origin, HEAD d218977):** 8140d40 S1 security-ACL SKIP→GREEN (authoritative access.log TCP_DENIED/HIER_NONE, standing suite 69/63/6/0, §11.4.169 matrix 10 PASS/1 SKIP); fe9d9a9 VPN-LAN comprehensive phased plan (12 phases, env-var bridge §11.4.28, SSRF-reconciled §11.4.120, 5 cited deep-research streams §11.4.150); 12faf12 **Phase 8 Miracast §11.4.112 structurally-impossible verdict** (cited Wi-Fi-Alliance, Cast alternative); 628d255 cmd/healthd coverage 59.5→70.3% (sample 0→100%, -race clean, conductor-re-verified); d781002 **Phase 0 env-var sword bridge scaffold** (.env.example + tests/lib/sword_bridge.sh + scripts/sword_doctor.sh + companion doc; 3 verdicts UP/SKIP/MISCONFIGURED reproduced); a5e5616 **Phase 9 operator bridge-setup guide; 5c28f56 wired test_vpn_lan_bridge into the standing suite** (bridge-down honest SKIP + §11.4.115 teeth UP-stub⇒UP, suite GREEN **71/64/7/0**); 182e80a **Phase 2/3 SMB/NFS + FTP/SFTP/WebDAV tests** (sha256 round-trip, wrong-answer⇒FAIL, bridge-down SKIP PASS_lines=0); 2f31460 **Phase 4 email + open-relay guard** (external-RCPT-accepted⇒FAIL, creds

via stdin never argv); d218977 **VPN-LAN integration Status + Status_Summary** (§11.4.45/§11.4.56). **Anti-bluff pattern proven:** every protocol test sources tests/lib/svord_bridge.sh, calls bridge_require FIRST, honest-SKIPs (exit 0, zero ^PASS:) when the bridge is down — never a fake PASS; ab_pass_with_evidence refuses a PASS without a non-empty captured artefact. **3 subagents in flight (§11.4.70/§11.4.103):** Phase 6/7 Chromecast+ADB tests, Phase 11 Challenge + HelixQA vpn_lan.yaml bank, Phase 5 discovery-reflector design+test. **Data-plane health FACT (§11.4.7):** base proxy 204 on a real endpoint via :53128; the fake-domain cache.example 503/000 is NOT a regression. Host 43%. **(prior) §11.4.126 autonomous hardening loop** (operator: "keep hardening, don't tag yet"). **P10 VPN fail-closed = GREEN:** dynamic stack booted, tunnel DOWN → branded 503 ERR_TUNNEL_DOWN ×3, leak_seen=0, Squid PID unchanged, deterministic ×3 + RED-polarity; egress-half operator-gated SKIP (§11.4.21). **2 security fixes landed + VERIFIED DEPLOYED LIVE** (§11.4.108 runtime-signature): Squid header/version-hygiene (via off+forwarded_for delete+version-suppression — Via gone) 4f983ee; Dante SOCKS5 SSRF (block link-local/loopback/RFC1918 + command:connect) 4626f05. **Rev-7 hardening wave (5 commits):** 790c191 **S4 SSRF guard hardened** — the SOCKS-block verdict now requires dante's authoritative block(N) log line (§11.4.69), NOT elapsed-time (an independent §11.4.142 review found the timing-only discriminator bluff-capable on fast-refuse hosts); **security guard now WIRED into the standing suite** (run-tests.sh test_security_guards, §11.4.135, GREEN+RED-polarity, set-e-safe) — iterate-to-GO (§11.4.134); 487c918 **cache challenge authoritative** — reads Squid's own access.log via podman exec → real TCP_MEM_HIT (§11.4.69), no more SKIP-fallback (Squid caching proven genuine); 3755702 **control-plane unit coverage** store 64.5→98.2% / vpn 78.6→98.1% / api 69.6→80.3% / healthd 61.3→67.6% (real error/fail-closed branches, race-clean, go.sum unchanged); 86126ac README §11.4.57 doc-link section; ad720ec this file → Rev 6. **2 items TRACKED-for-operator** (connectivity-risk §11.4.101): Squid dns_nameservers DNS-leak (static mode); Dante client-side open-relay. **§11.4.169 matrix = 9 PASS / 2 honest SKIP** (docs/design/hardening/Status.md Rev 3). **LE issuance + renewal BOTH PROVEN** — autonomous scope COMPLETE; Phase 4/6 OPERATOR-BLOCKED (§11.4.10). **Rev-8 increment (2 commits, subagent-driven §11.4.70 + conductor-reviewed pre-commit §11.4.142):** 017482a closed the §11.4.18 companion-doc gap (16 of 61 scripts → docs/scripts/<name>.md + synced HTML+PDF, all 16 PDFs §11.4.168 leak-clean, library function-lists cross-checked against real source §11.4.6); 0e987f1 raised control-plane internal/api unit coverage 80.3→95.8% (real error/fail-closed/500/mTLS-bootstrap branches, race-clean, go.mod/go.sum unchanged). HEAD 0e987f1 (== main == github/origin/upstream). **Branch:** main (operator directive 2026-07-01: "all work merged to main, all future work on main")

Spec: docs/superpowers/specs/2026-06-30-vpn-aware-proxy-extension-design.md (Rev 4) **Plan:** docs/superpowers/plans/2026-06-30-vpn-aware-proxy-extension-plan.md (Rev 1) **Authority:** Inherits the Helix Constitution submodule (constitution/Constitution.md) per §11.4.35.

§12.10 live-state resume file. Read this first, then `git fetch --all --prune` and `re-read git log --oneline main..HEAD`. Any agent must be able to resume exactly where the last session left off from this single file.

1. Current PHASE

§11.4.126 autonomous hardening loop — construction (P0–P10 fail-closed) is landed; the loop is now closing hardening gaps under all §11.4.169 test types with real captured evidence **AND has opened a new feature workstream: VPN-LAN service access** (operator mandate — reach/use all mainstream services on the far side of the sword_toolkit VPN). The authoritative phased tracker is docs/design/vpn_lan_access/PLAN.md (§11.4.172, 12 phases). Phase 0 (env-var bridge scaffold + sword-doctor) is in flight via a subagent; Phase 8 (Miracast §11.4.112 verdict) + a control-plane coverage push run in parallel. Operator decision in force: **"keep hardening, don't tag yet."** The Go control-plane (stores, health-publisher, acl-helper, config-compiler, P5b breaker/failover, P6 control-API/SSE/metrics/PAC/mTLS) builds + vets + gofmt-clean and is proven unit / integration / config-parse; the dynamic compose profile boots live and the **fail-closed data-plane proof is GREEN**. Base proxy UP on :53128 (204); host ~43%; 4 helixproxy_* Podman secrets present (enable dynamic re-boot).

P10 VPN fail-closed — GREEN (§11.4.68/.115/.108): tests/dynamic/vpn_failclosed_test.sh proven live — booted the dynamic stack, forced the tunnel DOWN via Redis `vpn:status, tunnel-DOWN` ⇒ branded 503 ERR_TUNNEL_DOWN ×3 (real 3132-byte page), leak_seen=0, Squid PID unchanged; deterministic ×3 (§11.4.50) + RED polarity guard FAILs a fabricated 200 leak (§11.4.115). Real-VPN-egress half is operator-gated SKIP (gluetun WireGuard creds §11.4.21). Evidence qa-results/dynamic/vpn_failclosed/20260701T130115Z/. Re-runnable boot recipe: 4 external Podman secrets from tests/observability/gen_test_mtls.sh → `./start --dynamic` (backgrounded) → poll proxy-squid Up + compiler renders dynamic-routing.squid → `HELIX_DYNAMIC_STACK=1 GOMAXPROCS=2 nice -n 19 ionice -c 3 bash tests/dynamic/vpn_failclosed_test.sh`; restore base after: `./stop && ./start`.

2 real security fixes (config-security review, docs/design/security/Status.md Rev 2) — RED→GREEN + sink-side evidence + standing guards:

- Squid header/version-hygiene (4f983ee): via off + forwarded_for delete + httpd_suppress_version_string on + visible_hostname helix-proxy in squid.conf + squid.dynamic.conf. The Via: 1.1 proxy-squid (squid/6.13) leak was CONFIRMED live (RED) → GONE (GREEN). Guard: proxy_acl_security.sh S3. **Root-cause note:** single-file :ro bind mounts pin the inode → config edits need a container **recreate** (./stop && ./start), NOT squid -k reconfigure (re-reads the stale inode).
- Dante SOCKS5 SSRF (4626f05): command: connect + socks block for 127/8, 169.254/16, 10/8, 172.16/12, 192.168/16 in sockd.conf. 5 internal targets refused fast (code 000 ~0.01s, dante-log block(N)), external control 204, no public-egress regression. Guard: proxy_acl_security.sh S4.

2 items TRACKED-for-operator (§11.4.101 connectivity-risk, NOT autonomously fixed): (1) Squid dns_nameservers 8.8.8.8 bypasses the DoT dnsproxy → DNS leak in **static** mode (dynamic mitigated by never_direct); re-point = risk. (2) Dante socksmethod none + client pass from:0.0.0.0/0 open-relay if :51080 escapes the bridge; client-CIDR restriction = risk. O(1) table in docs/design/security/Status.md.

§11.4.169 hardening matrix (docs/design/hardening/Status.md Rev 3) — 9 PASS / 2 honest SKIP: PASS = stress+chaos, DDoS(300/300), concurrency(40, crosstalk=0), memory(ratio 1.0017), **P10 fail-closed, race/deadlock (0 DATA RACE, 11 pkgs), benchmark (200/200, p50=86ms/p95=88ms/p99=91ms, 10.84 req/s)** + unit/integration. SKIP (honest §11.4.3) = security ACL live-deny (no autonomous deny topology) + P10 egress-half (gluetun creds).

Remaining actionable (non-operator-gated) is thinning. Operator-gated: 2 TRACKED security items (connectivity risk), LE Phase 4/6, P10 real-egress (gluetun creds), HelixQA vendoring (6 un-vendored siblings), release tag.

2. Landed commits (newest first)

main FF-tracks HEAD (§11.4.113 FF-only), so main..HEAD is empty — HEAD == main == github/origin/upstream == 4dd5fc 6. The full feature-branch history since the original branch point is below; the historical table (numbered 1-28) is retained for the earlier construction wave.

Latest hardening wave (newest first):

Commit	Lane	Summary
0e987f1	control-plane	internal/api unit coverage 80.3→95.8% (real 404/400/500/502/fail-closed-TLS/metrics-suppression branches, race-clean, go.mod unchanged) — subagent-driven (§11.4.70), conductor-reviewed (§11.4.142)
017482a	docs	16 §11.4.18 companion docs (previously-undocumented test/challenge/lib scripts) + synced HTML+PDF, all §11.4.168 leak-clean, library fn-lists source-verified (§11.4.6)
790c191	security	S4 SSRF guard → authoritative dante block(N) log-line discriminator (§11.4.69) + security guard wired into standing suite (§11.4.135) — independent-review-driven (§11.4.142/.134)
487c918	challenge	proxy cache challenge → authoritative TCP_*HIT via container access.log (§11.4.69), no more SKIP-fallback (Squid caching proven genuine)
3755702	control-plane	unit coverage store 64.5→98.2% / vpn 78.6→98.1% / api 69.6→80.3% / healthd 61.3→67.6% (real error/fail-closed branches, race-clean)
86126ac	docs	README §11.4.57 Tracked-Items doc-link section (9 Status docs)
ad720ec	docs	CONTINUATION → Rev 6 (§12.10 sync: P10 GREEN + security fixes + §11.4.169 matrix)
4626f05	security	Dante SOCKS5 SSRF hardening — block internal/link-local/loopback egress + command:connect (RED→GREEN + S4 guard)
4d0a7ed	control-plane	drop dead nil-check in TestPostgresSatisfiesQueries (golangci SA4023)
916e72b	helixqa	unblock recipe for the proxy test bank (6 un-vendored own-org siblings)
8833ccc	letsencrypt	cert-analyzer edge-case coverage 37→55 (validity boundaries, malformed PEM, empty/IP/mixed SAN, double-wildcard)
4f983ee	security	Squid header/version-hygiene hardening (via off + forwarded_for delete + version suppression) — RED→GREEN + S3 guard
1caaf51	hardening	

Commit	Lane	Summary
567c9e1	hardening	control-plane unit(100-61%)+Go-benchmarks+audit-atomicity-verified + Challenges 2/3 + §11.4.169 matrix sync P10 VPN fail-closed GREEN + race(0)/benchmark(p50=86ms) + §11.4.169 Status matrix

Earlier construction wave (historical, numbered from the original branch point):

#	Commit	Phase	Summary
28	8d95f8a	P6	real bidirectional metric-name drift guard (§1.1-mutation-proven) + concurrency consistency test; WARNING-3/4/5
27	2bc03de	BUGFIX-0006	revive + de-bluff comprehensive-test.sh ((()) abort = 100% dead) + real B2/B3/B8 evidence; surfaced regression #50
26	4394643	BUGFIX-0005	final-verify.sh + verify-proxy.sh no longer green a NO-VPN config (false-VPN-routing §15) + set -e abort
25	cd11494	BUGFIX-0004	run-tests.sh no longer FAILs a healthy proxy — §11.4.3 topology-aware ports + 3-state SKIP
24	6a8f886	P11	refresh CONTINUATION to live state (Rev 2) — 23 commits, P5b/P6/BUGFIX-0002/0003 landed, P8 in flight
23	61b4215	chore	gofmt-format 6 pre-existing files (formatters-clean mandate; semantics-null verified)
22	62b22fe	P6	control-API server (REST/SSE/metrics/PAC, fail-closed mTLS) + coherent operator-wiring contract
21	1045dfd	BUGFIX-0003	test_result must return 0 — suite no longer aborts mid-run under set -e
20	c6f2935	P9	§11.4.18 operator-guide companions for the 16 tests/dynamic scripts
19	b5573a9	BUGFIX-0002	squid log-dir writable under rootless Podman (proxy crash-

#	Commit	Phase	Summary
			loop) — existing features now serve live
18	0aca034	P9	anti-bluff dynamic-routing test/ analyzer harness (tests/dynamic)
17	e6e93ec	P10-prep	dynamic compose profile + control-plane/squid Containerfiles + orchestrator wiring
16	6bdeef9	P5b	circuit-breaker + tier-failover (internal/breaker, gobreaker/v2)
15	7d0d128	P11	CONTINUATION (§12.10) + spec §9 reconcile + §11.4.65 HTML/ PDF export backfill
14	1833c8f	P7.3	per-user Squid auth + rootless Podman-secret loader + kill-switch design (no secrets)
13	603e039	P5a	acl-helper — Squid external_acl OK/ERR from Redis, fail-closed (stdlib)
12	e6e336f	P7.1	per-tunnel DoH/DoT (dnsproxy) config plan + DNS-leak test design
11	04526dd	P4	config-compiler — render Squid/ Dante/PAC from PG + seed route keys (parse-verified)
10	833fb9e	P7.2	Prometheus scrape + Grafana dashboard config plan (promtool-validated)
9	11106a4	P3	vpn-health-publisher (cmd/ healthd + internal/vpn) — data-plane health, fail-closed, TDD
8	b66d172	P4	Squid 6.13 + Dante dynamic-mode templates (additive, parse-verified) + spec reconcile
7	fbfe9ed	P1	docs(spec): mark §20 gaps G1-G4 RESOLVED with spike decisions
6	e19e0ed	P2	store (pgx) + redis (go-redis) clients — fail-closed, TDD, real PG/Redis
5	6409cb9	P1	docs(research): resolve spec §20 gaps G1-G4 with captured-evidence spikes
4	6802798	P1/E	docs(audit): §11.4.138 forensic bluff-audit of 4 existing test scripts (8 bluffs)

#	Commit	Phase	Summary
3	9ac1b4a	P0	docs(dynamic-routing): DYNAMIC_ROUTING.md + 2 mermaid diagrams
2	6251007	P0	chore(submodules): incorporate containers, helix_qa, challenges, docs_chain (SSH, no-force)
1	5f917a7	P0	P0 scaffold — data model, evidence harness, Go skeleton, governance carriers

3. PROVEN-NOW vs OWED-TO-P10 (honest §11.4.6)

PROVEN-NOW (control-plane / config-plane / spike facts — captured)

- **Existing proxy serves LIVE (BUGFIX-0002)** — after the rootless-Podman log-dir fix, the booted --no-vpn stack proves all 3 existing features: HTTP forward proxy 200 + Via: 1.1 proxy-squid, Dante SOCKS5 200, squid cache TCP_MEM_HIT (no origin contact). Guard: tests/regression/log_dir_writable_test.sh (§11.4.115 polarity, §1.1 mutation byte-identical md5 0128a96b6d467c2da5b7cef8a808e563). Evidence: qa-results/regression/bugfix38/.
- **P5b breaker/failover** (internal/breaker, gobreaker/v2) — per-target circuit breaker + tunnel tier-failover, TDD.
- **P6 control-API** (cmd/api + internal/api + internal/pac) — REST CRUD + SSE + Prometheus /metrics + PAC, **fail-closed mTLS** (RequireAndVerifyClientCert), coherent operator-wiring contract (CONTROL_API_TLS_CERT/_KEY/_TLS_CLIENT_CA, :58080); builds + vets clean, §1.1 mutation md5 67125c7a1ab9b00c98fb164f765b04af.
- **Spec §20 gaps G1-G4 resolved** with transient-spike captured evidence (docs/research/mvp/findings/F_spikes_G1-G4.md, run-id qa-results/spikes/20260630_205029_g1g4/): G2 ubuntu/squid:latest = Squid **6.13** (not v8), §8 directive set squid -k parse exit 0; G4 gluetun **v3.40 (=v3.40.4)** control-API :8000 answers 200, issue #3060 confirmed; G1 kernel-WG interface **creatable rootless** with --cap-add NET_ADMIN; G3 Dante **SIGHUP preserves an active SOCKS session** (20/20 chunks, curl exit 0, /proc/net/tcp ESTABLISHED proof).
- **P2 stores** (pgx + go-redis) — fail-closed, TDD, exercised against **real PG / Redis**.
- **P3 vpn-health-publisher** (cmd/healthd + internal/vpn) — data-plane health poll → Redis state, fail-closed, TDD.

- **P4 config-compiler + templates** — Squid 6.13 (%>ha{Host}) + Dante (concatenation, no include) render from PG; **squid -k parse exit 0**; PAC + route-key seeding parse-verified.
- **P5a acl-helper** — Squid external_acl OK/ERR from Redis, **fail-closed**, stdlib-only.
- **P7.2 observability** config plan — **promtool-validated** Prometheus scrape + Grafana dashboard.
- **P7.1 DNS / P7.3 security** — config plans only (DoH/DoT per-tunnel; per-user auth + Podman-secret loader + in-netns kill-switch). Design + parse layer.
- **Existing-test bluff audit** (Stream E) — 8 bluffs across 4 scripts catalogued (§11.4.138), guards owed to P8.

CAPTURED-AT-P10 (fail-closed data-plane proof — the dynamic stack HAS booted)

The dynamic compose profile (postgres + redis + control-plane + squid+helper + dante) now **boots live**; the fail-closed half of the usability proof is captured:

- graceful_503 — **PROVEN**: tunnel DOWN (Redis vpn:status) → branded 503 ERR_TUNNEL_DOWN ×3 (3132-byte page) with **Squid PID unchanged**; deterministic ×3 + RED-polarity guard. Evidence qa-results/dynamic/vpn_failclosed/20260701T130115Z/.
- no_leak (tunnel-down case) — **PROVEN**: leak_seen=0 during the DOWN window (no target reached while the tunnel is down).

OWED-TO-P10 (real-VPN-egress half — operator-gated on gluetun WG creds)

Requires real gluetun WireGuard credentials (§11.4.21); still **unproven live**:

- vpn_real_egress — egress IP via proxy
== tunnel exit && != host IP + **wg transfer Δ** (200 OK is not routing).
- no_leak / killswitch (up→drop case) — drop a *real* tunnel → **zero** target packets on the real uplink (tcpdump) + DNS only via the intended resolver.
- per-user **407 auth challenge** live; **secret injection leak-free** at runtime.
- **G1 residual** — full rootless kernel-WG *operation* (handshake + routing + throughput), only interface *creation* was spiked (§20 G1).
- **G3 residual / P9** — concurrent / repeated SIGHUP + **route-change-mid-session** SOCKS path behaviour (§20 G3).
- circuit-breaker open → failover to next up tier — **landed** (6bdeef9, P5b); live-under-load failover proof still owed.

4. Remaining phases

Phase	Scope	State
P5b	per-target circuit breaker + tunnel tier-failover (sony/gobreaker/v2)	landed 6bdeef9
P6	control-API + SSE + metrics + PAC + fail-closed mTLS	landed 62b22fe (admin-UI templ/htmx + §11.4.170 host-rendered pixel proof = P6.2, deferred)
P8	fix existing-test bluffs → §11.4.3 topology dispatch / honest SKIP / §11.4.161 + §11.4.135 guards	landed (cd11494/4394643/2bc03de/8d95f8a)
P9	full test matrix + Challenges + HelixQA (all §11.4.169 types; G3 route-change-mid-session live test)	§11.4.169 matrix GREEN (9 PASS/2 SKIP); Challenges 2/3; HelixQA vendoring operator-gated (6 siblings)
P10	live dynamic-mode boot + captured data-plane evidence = the usability proof	fail-closed half GREEN (567c9e1); real-egress half operator-gated (gluetun WG creds §11.4.21)
P11	docs sync + HTML/PDF (+DOCX where mandated) exports (this CONTINUATION + .remember are part of it)	ongoing (this Rev 6 sync)
P12	whole-branch review (iterate-to-GO) + full retest + merge to main no-force + prefixed release tag	operator-gated — "keep hardening, don't tag yet"

5. Binding constraints (non-negotiable)

- **Anti-bluff §11.4** — every PASS carries positive captured **data-plane** evidence; control-plane/config-parse green is necessary, never sufficient; the end-user-usability bar is met only at P10.
- **No force-push §11.4.113** — merge onto latest main, fast-forward only; force-push is forbidden with no exception.
- **Rootless Podman §11.4.161** — all containers rootless; no Docker-rootful, no sudo, no root escalation; orchestrate via the containers submodule (§11.4.76), build on the remote host (§11.4.173).

- **Secrets-as-names-only §11.4.10** — VPN creds / proxy-auth / mTLS keys via Podman secrets / file refs; **never** plaintext in git; .env.example documents refs only.
- **Operator-safe §11.4.174** — do **NOT** touch the operator's pre-existing resources: the host wg0-mullvad (UP kernel-WG) interface and any lava-* containers (e.g. lava-postgres-thinker) are off-limits; verify process/resource ownership before acting; block-don't-break on shared-host contention.
- **Host safety §12** — ≤60% memory (§12.6); no host power-state commands (CONST-033); pull images sequentially; --rm diagnostics; df first.

6. Resume now (next actionable)

1. git fetch --all --prune on **main** (operator: all work on main); confirm HEAD 91af9c6 (== main == origin; integrate any newer foreign commit per §11.4.71, no force §11.4.113). The single canonical moment-valid resume file is .remember/remember.md (§11.4.131) — read it first. **Hermetic H0→H2 is DONE + HARDENED:** the H0-full real kernel-WireGuard tunnel (hermetic_wg_roundtrip.sh) + the model-A protocol promotions over it are all landed + independently reviewed + wired into the standing suite as §11.4.135 guards (test_vpn_lan_hermetic in tests/run-tests.sh), and all 5 harnesses now carry the §11.4.111 wrong-destination negative control (proven load-bearing — bind-0.0.0.0 ⇒ harness FAILs). **The clean zero-install promotion set is COMPLETE (§11.4.6): Cast-eureka + FTP + WebDAV + email** all run AUTONOMOUSLY over the tunnel (unmodified protocol tests, stdlib peers on 10.10.0.2, golden-bad teeth, 3/3 deterministic). Remaining protocol legs are genuinely operator-gated (§11.4.122/§11.4.3): SFTP (no sshd), SMB/NFS (no samba/nfsd), discovery_reflect.sh scored leg (no avahi-browse client), ADB (device), container (podman) — do NOT manufacture bluff harnesses for these. **The underlay-sniff AF_PACKET non-leak differential (task #63) is LANDED on the WG substrate** (91af9c6, hermetic_wg_roundtrip.sh, independent §11.4.142 review a2b3c696 GO 11/11): during the positive round-trip it captures on the underlay veth0 and asserts BOTH ciphertext present (type-4 0x04 datagram to :51820) AND the per-run plaintext nonce ABSENT in raw underlay bytes; load-bearing golden-bad SNIFF_MUT=plain flips ONLY "plaintext absent" to FAIL (not a tautology, §11.4.107(10)), honest exit-3 on empty capture, honest SNIFF-SKIP when unavailable, 3/3 deterministic. FINDINGS §7 → Rev 4 (PLANNED → IMPLEMENTED). **Top non-operator-gated actionables now: (task #64, tiny)** a one-line Ethernet-ethertype guard on the sniff frame analyzer (reviewer nit — a VLAN tag would shift Eth/IPv4/UDP offsets; structurally impossible on the harness's own fresh veth, so correct-by-construction hardening

+ a crafted-pcap unit assertion); **(task #65, fan-out)**
replicate the sniff differential on the 4 protocol harnesses
(hermetic_bridge_run.sh/_ftp_run.sh/_webdav_run.sh/
_email_run.sh), each with a per-protocol plaintext marker
(eureka JSON / FTP listing / WebDAV 207 body / mail token) +
its own load-bearing SNIFF_MUT=plain. Both: builder →
independent §11.4.142 review iterate-to-GO §11.4.134 → FF
push; run ONE netns owner at a time (§11.4.119). Design docs/
design/vpn_lan_access/hermetic_wg_test_harness.md Rev 2.

2. **Continue the §11.4.126 autonomous hardening loop**
(operator: "keep hardening, don't tag yet"). Base proxy UP
:53128 (204); ~43% host; 4 helixproxy_* Podman secrets
present. Keep dispatching 3-4 parallel non-data-plane
subagents on remaining actionable items (§11.4.103); the data
plane / :53128 has a single owner (§11.4.119) — coordinate
before any boot.
3. **P10 fail-closed — GREEN + guarded (567c9e1)**. Real-VPN-
egress half remains operator-gated on gluetun WireGuard
creds (§11.4.21/.66). To re-run fail-closed: 4 secrets from
tests/observability/gen_test_mtls.sh → ./start --dynamic
(backgrounded) → HELIX_DYNAMIC_STACK=1 ... bash tests/dynamic/
vpn_failclosed_test.sh → restore base ./stop && ./start.
4. **LE — issuance + renewal BOTH PROVEN (autonomous
scope COMPLETE)**. Phase 3 hermetic DNS-01 issuance +
Phase 5 zero-downtime renewal/rotation are cert-analyzer-
verified, re-runnable, and guarded (tests/letsencrypt/
phase3_issuance_guard.sh + phase5_rotation_guard.sh, wired in
run-tests.sh); custom Caddy image via deploy/letsencrypt/
build.sh; cert-analyzer self-test 37→55 (8833ccc). Phase 4 (LE-
staging token §11.4.10)
 - Phase 6 (prod domain) OPERATOR-BLOCKED. Docs docs/
design/letsencrypt/Status.md.
5. **Operator-gated queue (surface, don't autonomously
break)**: 2 TRACKED security items (Squid dns_nameservers
DNS-leak, Dante client-side open-relay — both connectivity-
risk §11.4.101); LE Phase 4/6; P10 real-egress (gluetun creds);
HelixQA vendoring (6 un-vendored siblings, docs/helixqa/
UNBLOCK.md); the release tag helix_proxy-0.1.0-dev-0.0.2
(operator said don't tag yet).
6. Every change: TDD reproduce-first (§11.4.43/§11.4.115), all
warranted test types (§11.4.169), paired §1.1 mutation,
independent review → iterate-to-GO (§11.4.142/§11.4.125/
§11.4.134), docs in sync (§11.4.60/§11.4.65/§11.4.106),
operator resources untouched (§11.4.174: wg0-mullvad, lava-*,
whoami:58080).